

Zde je přehledný abecední slovník nejdůležitějších zkratk rozdělený do logických celků. Definice jsou formulovány exaktně, aby ti pomohly rozpoznat správnou možnost v testu typu A, B, C a nezaměnit podobné pojmy.

1. Česká legislativa a národní instituce

- **nZKB (Nový zákon o kybernetické bezpečnosti):** Zákon č. 264/2025 Sb., který nahrazuje starý zákon č. 181/2014 Sb. a transponuje evropskou směrnici NIS2 do českého právního řádu.
 - **NÚKIB (Národní úřad pro kybernetickou a informační bezpečnost):** Ústřední orgán státní správy pro kybernetickou bezpečnost v ČR, který vede registr poskytovatelů regulovaných služeb a přijímá povinná hlášení incidentů.
 - **MPO (Ministerstvo průmyslu a obchodu):** Nadřízený resort státní správy, který řídí ÚNMZ a pověřuje národní akreditační orgán.
 - **ÚNMZ (Úřad pro technickou normalizaci, metrologii a státní zkušebnictví):** Organizační složka státu pod MPO, která formálně schvaluje české technické normy (ČSN), uděluje autorizace a vydává Věstník Úřadu.
 - **ČAS (Česká agentura pro standardizaci):** Státní příspěvková organizace zřízená ÚNMZ, která od 1. 1. 2018 kompletně zajišťuje tvorbu, vydávání a distribuci norem ČSN.
 - **ČIA (Český institut pro akreditaci, o.p.s.):** Jediný ministerstvem pověřený národní akreditační orgán v ČR, který posuzuje způsobilost laboratoří a certifikačních orgánů a vydává Osvědčení o akreditaci.
 - **ČMI (Český metrologický institut):** Subjekt zajišťující výkon státní metrologie, uchovávání národních etalonů a kalibraci měřidel.
 - **CCZ (Česká značka shody):** Značka shody umisťovaná na výrobky, na které se **nevztahují** harmonizační předpisy Evropské unie.
 - **CE (Conformité Européenne):** Označení na výrobku potvrzující splnění technických požadavků všech relevantních evropských direktiv a nařízení vlády.
-

2. Mezinárodní a evropské standardizační orgány

- **ISO (Mezinárodní organizace pro normalizaci):** Celosvětová federace národních normalizačních orgánů se sídlem v Ženevě, která vytváří dobrovolné de jure normy pro všechna odvětví vyjma elektrotechniky.
 - **IEC (Mezinárodní elektrotechnická komise):** Globální organizace vytvářející mezinárodní standardy pro oblast elektrotechniky, elektroniky a příbuzných technologií.
 - **IETF (Internet Engineering Task Force):** Otevřené mezinárodní společenství zaměřené na technický rozvoj a standardizaci architektury Internetu, které schvaluje a vydává dokumenty RFC.
 - **NIST (National Institute of Standards and Technology):** Vládní standardizační úřad USA (nástupce NBS z roku 1901), který vydává celosvětově vlivné kryptografické standardy FIPS a doporučení SP (*Special Publications*).
 - **CEN (Evropský výbor pro normalizaci):** Regionální sdružení národních normalizačních orgánů v Bruselu vytvářející evropské normy (EN) pro neelektrotechnické obory.
 - **CENELEC (Evropský výbor pro elektrotechnickou normalizaci):** Evropská organizace v Bruselu harmonizující technické normy v oblasti elektrotechnického průmyslu.
 - **ETSI (Evropský institut pro normalizaci v telekomunikacích):** Organizace ve Francii vyvíjející globální standardy pro ICT (např. sítě 4G/5G). *Pozor:* ČAS zde má pouze status pozorovatele.
 - **ENISA (Agentura EU pro kybernetickou bezpečnost):** Unijní agentura se sídlem v Aténách, která vypracovává návrhy jednotných evropských certifikačních schémata.
-

3. Bezpečnostní kritéria, hodnocení a akreditace

- **TCSEC (Trusted Computer System Evaluation Criteria / Oranžová kniha):** Historická armádní kritéria USA z roku 1985 zaměřená monoliticky na **důvěrnost** informací v sálových počítačích.
- **ITSEC (Information Technology Security Evaluation Criteria):** Evropská harmonizovaná kritéria z roku 1991 pokrývající celou třídu **CIA** a oddělující **funkčnost** od **záruk**.
- **CTCPEC (Canadian Trusted Computer Product Evaluation Criteria):** Historická kanadská kritéria, která zavedla rozdělení služeb do profilů a strukturované hodnocení záruk.
- **FC (Federal Criteria):** Společný návrh NIST a NSA z roku 1992, který poprvé definoval přelomový koncept *Bezpečnostního profilu*.
- **CC (Common Criteria / Společná kritéria):** Moderní mezinárodní standard (ISO/IEC 15408) pro nezávislé hodnocení bezpečnostních vlastností IT produktů, nástupce historických národních kritérií.
- **CCRA (Common Criteria Recognition Arrangement):** Globální vládní dohoda o vzájemném mezinárodním uznávání CC certifikátů, která je striktně omezena **pouze do úrovně EAL4**.
- **SOG-IS (Senior Officials Group Information Systems Security):** Užší evropská platforma, která umožňovala vzájemné uznávání certifikátů i na vysokých úrovních EAL5–EAL7 pro specifické hardwarové domény. V únoru 2026 ukončila vydávání nových certifikátů.
- **EUCC (European Cybersecurity Certification Scheme based on CC):** Nové jednotné unijní dobrovolné schéma kyberbezpečnostní certifikace produktů, které plně nahrazuje a absorbuje systém SOG-IS.
- **CEM (Common Evaluation Methodology):** Celosvětově unifikovaná příručka a metodologie závazných postupů pro laboratorní zkoumání produktů podle CC.
- **EAL (Evaluation Assurance Level):** Předdefinovaný balíček požadavků na záruky bezpečnosti v CC, škálovaný v sedmi hierarchických úrovních (EAL1 až EAL7).
- **PP (Protection Profile / Profil ochrany):** **Implementačně nezávislý** dokument vyjadřující obecné bezpečnostní požadavky na celou kategorii produktů (např. šablona pro firewally).
- **ST (Security Target / Bezpečnostní cíl):** **Implementačně závislý** dokument popisující reálné technické mechanismy a vlastnosti **jednoho konkrétního produktu** podrobovaného testům v laboratoři.
- **SFR (Security Functional Requirements):** Technické funkční požadavky na chování produktu v CC (např. kryptografické operace, audit).
- **SAR (Security Assurance Requirements):** Procesní požadavky na záruky bezpečnosti v CC (hodnotí proces vývoje, testování, správu konfigurace a dokumentaci).
- **TOE (Target of Evaluation / Předmět hodnocení):** Označení pro samotný IT produkt, software nebo hardware, který je podrobován nezávislému zkoumání podle CC.
- **TSF (TOE Security Functionality):** Souhrn všech vnitřních mechanismů a funkcí Předmětu hodnocení, které aktivně zajišťují jeho bezpečnost.
- **CAB (Conformity Assessment Body / Subjekt posuzování shody):** Nezávislý akreditovaný a notifikovaný subjekt (zkušební laboratoř, certifikační orgán), který v praxi ověřuje shodu produktů se standardy.
- **ITSEF (IT Security Evaluation Facility):** Licenční označení pro specializovanou komerční testovací laboratoř kybernetické bezpečnosti oprávněnou provádět evaluace podle CC/EUCC.

4. Kryptografie a internetové protokoly

- **RFC (Request for Comments):** Specifická internetová dokumentace a de facto technické standardy Internetu vydávané IETF, podléhající striktnímu principu textové neměnnosti čísla dokumentu.
 - **PKCS (Public-Key Cryptographic Standards):** Soubor celosvětově dominantních de facto standardů pro infrastrukturu veřejného klíče (PKI) původně vyvinutých laboratořemi RSA Security (např. PKCS #11 pro tokeny/HSM, PKCS #12 pro chráněné kontejnery klíčů).
 - **PKI (Public Key Infrastructure):** Infrastruktura veřejného klíče – komplexní systém hardwaru, softwaru, certifikačních autorit (CA) a politik určený pro správu digitálních certifikátů a asymetrických klíčů.
 - **FIPS (Federal Information Processing Standards):** Oficiální vládní standardy USA vydávané NISTem pro potřeby federálních úřadů (např. FIPS 140-3 pro šifrovací moduly).
 - **PQC (Post-Quantum Cryptography):** Postkvantová kryptografie – nová generace algoritmů (např. ML-KEM, ML-DSA) navržených tak, aby byly odolné proti útokům ze strany budoucích kvantových počítačů.
 - **CSR (Certificate Signing Request):** Standardizovaná datová struktura (PKCS #10) zasílaná uživatelem certifikační autoritě (CA) s žádostí o podepsání a vydání certifikátu k jeho veřejnému klíči.
 - **HSM (Hardware Security Module):** Hardwarový bezpečnostní modul – specializované fyzické zařízení chráněné proti neoprávněné manipulaci, určené pro bezpečné generování, ukládání a provádění kryptografických operací s klíči.
 - **Cryptoki (Cryptographic Token Interface):** Obecné programové rozhraní (API) vymezené standardem PKCS #11, které unifikuje komunikaci aplikací s hardwarovými kryptografickými tokeny a HSM moduly.
-

5. Management, Analýza rizik a Provoz

- **ISMS (Information Security Management System):** Systém řízení bezpečnosti informací – systematický a procesní přístup k řízení citlivých firemních informací tak, aby zůstaly chráněny (hlavní norma: ISO/IEC 27001).
- **PDCA (Plan-Do-Check-Act):** Kontinuální čtyřfázový manažerský model (Plánuj – Dělej – Kontroluj – Jednej) implementovaný v systémech řízení podle ISO norem.
- **SoA (Statement of Applicability / Prohlášení o aplikovatelnosti):** Klíčový dokumentovaný výstup ISMS obsahující taxativní přehled opatření z Přílohy A normy ISO 27001, která jsou relevantní a implementovaná v dané organizaci.
- **HS (Harmonized Structure / Harmonizovaná struktura):** Povinná, unifikovaná šablona o 10 kapitolách určená pro autory mezinárodních norem ISO, garantující stejný jazyk a logiku (dříve Annex SL).
- **ALE (Annual Loss Expectancy):** Očekávaná roční ztráta – kvantitativní ukazatel v analýze rizik vyjadřující finanční odhad ročních škod při realizaci konkrétního rizika.
- **EAC (Estimated Annual Cost):** Odhadované roční náklady – ekonomický finanční ukazatel vyjadřující celkové předpokládané roční náklady spojené s provozem bezpečnostních opatření.
- **GRC (Governance, Risk, and Compliance):** Komplexní korporátní strategie a softwarové nástroje pro integrované řízení správy společnosti, analýzy rizik a sledování souladu s legislativou.
- **CMDB (Configuration Management Database):** Databáze řízení konfigurací – strukturované úložiště (registru) evidující veškeré IT prvky (aktiva), jejich technické parametry a vzájemné logické vazby.
- **BCM (Business Continuity Management):** Řízení kontinuity podnikání – manažerský proces zaměřený na identifikaci potenciálních dopadů havárií a budování plánů pro zajištění nepřetržitého provozu klíčových služeb.
- **DRP (Disaster Recovery Plan):** Plán obnovy po havárii – podrobný technický a procesní scénář kroků nezbytných pro rychlou obnovu IT infrastruktury a datových center po kritickém výpadku či katastrofě.

- **IAM (Identity and Access Management):** Řízení identit a přístupových práv – technický a organizační systém pro správu uživatelských účtů, přidělování oprávnění (RBAC) a ověřování identity (MFA).
- **SOC (Security Operations Center):** Centralizované bezpečnostní operační středisko zajišťující nepřetržitý (24/7) monitoring síťového provozu, detekci anomálií a prvotní reakci na kybernetické incidenty.
- **SIEM (Security Information and Event Management):** Softwarový systém pro centralizovaný sběr, analýzu, korelaci a dlouhodobé ukládání bezpečnostních logů a událostí z celé IT infrastruktury.
- **CIA (Confidentiality, Integrity, Availability):** Základní bezpečnostní triáda vlastností informací: **Důvěrnost** (přístup jen oprávněným), **Integrita** (správnost a úplnost dat), **Dostupnost** (přístupnost v okamžiku potřeby).